

Reflection

Melvin Viado

Cybersecurity, Durham College

INFT1204: Special Topics and Cybersecurity

Vigna Thanikaslam

January 29, 2026

No Certification Revocation

Upon extensive research about this subject, I have learned that the absence of certification revocation consists of systems failing to invalidate outdated or expired certificates, allowing attackers access to communications or services upon taking those certificates. This results in prolonged attacks if those certificates can be used to validate access which can come from misconfigurations, network failures, and lack of security features.

Risks

If a certificate is compromised but the certificate remains valid until natural expiry, the security of the given online communications is lost. Some attacks resulting from this event are Man-in-the-Middle attacks, website impersonation, traffic decryption, and malware distribution. Attacks can view and alter traffic between users and servers where they can steal credentials, credit card numbers, or any other sensitive and personal data. Without revocation of certifications, attackers can continue to steal data and information, spread malware, and impersonate legitimate websites or personnel.

Operational Challenges

Validating certificates usually relates to the use of Online Certificate Status Protocols (OCSP) and Certificate Revocation Lists (CRL). These features can revoke compromised certificates and update them to hold trust between clients and servers. Reasons an organization may disable these features is due to system performance, network availability, and general user experience. CRL checking can be resource-intensive, OCSP responder servers may be down, and communication to certificate servers may be interrupted by network issues.

Best Practices

Digital certificates should be immediately revoked when it is suspected or confirmed that it is stolen, when it is issued without proper authorization, or when a new certificate is issued to replace the old one. Additional reasons to revoke a certificate is if an organization changes their name, or if a certificate uses a weak cryptographic algorithm. Real-time monitoring and system logs are used to detect failures in certificate revocation specifically relating to Certificate Revocation Lists or Online Certificate Status Protocol.